

1. Aspecte privind managementul cheilor criptografice

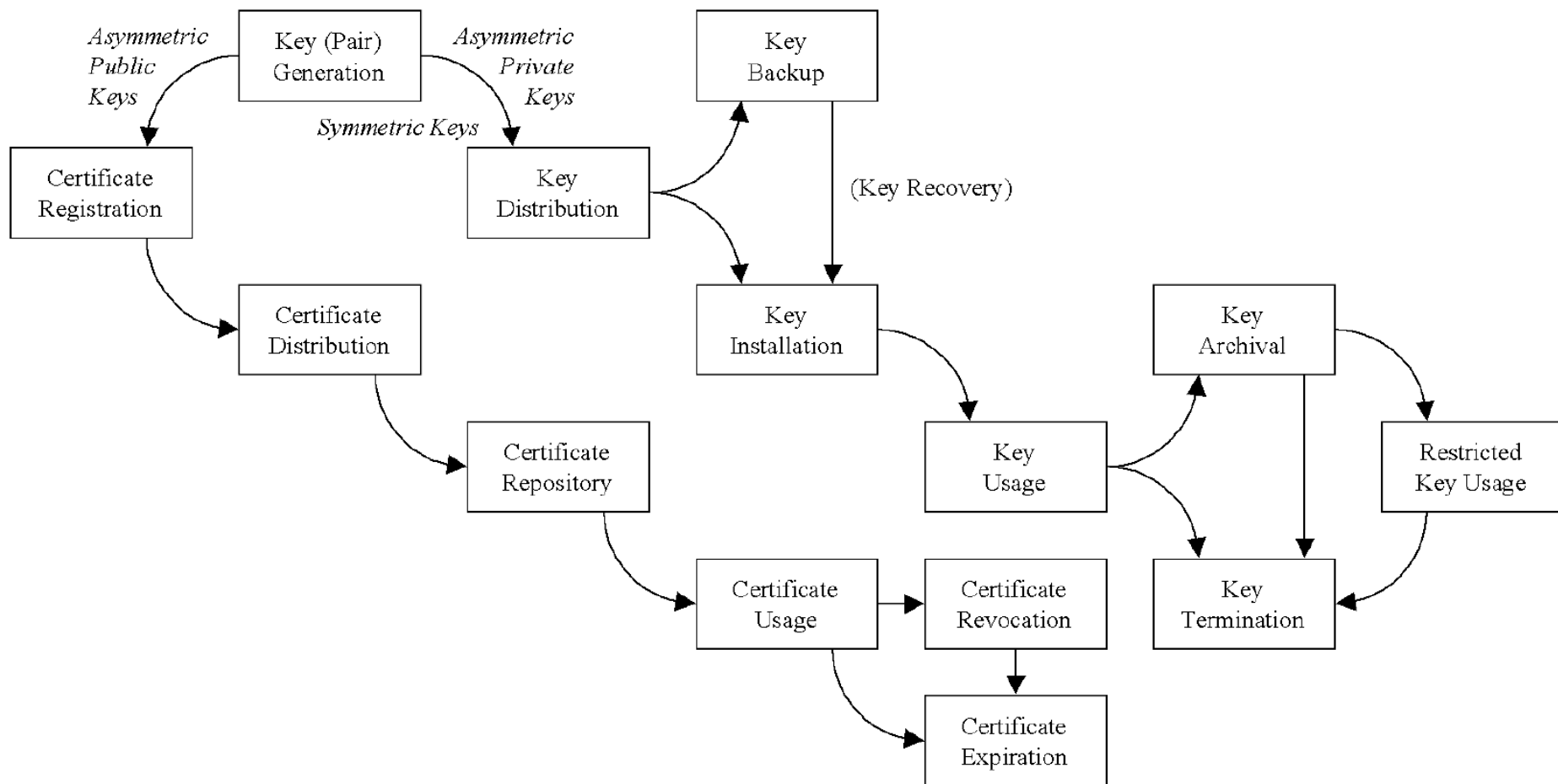
Managementul cheilor criptografice

- Securitatea unui sistem criptografic depinde în mare parte de modul în care se realizează managementul cheilor
 - cel mai sigur seif din lume nu valorează nimic atunci când combinația de numere necesară deschiderii seifului a fost aflată de adversar
- Aspect specific implementării practice a sistemelor criptografice
 - pot apare erori atât în partea de implementare cât mai ales în partea de exploatare
- Cauza pentru care multe sisteme criptografice au fost “sparte”
- Greu să nu faci greșeli atâta timp cât factorul uman joacă un rol foarte important în acest proces

Managementul cheilor criptografice (cont.)

- Managementul cheilor = administrarea sigură a cheilor criptografice pe tot parcursul ciclului de viață al acestora
- Managementul cheilor simetrice
- Managementul cheilor publice/private
 - Infrastructuri de Chei Publice (PKI)
- Pentru toate tipurile de chei trebuie asigurată integritatea
- Cheile secrete și cele private trebuie protejate împotriva dezvăluirii neautorizate

Ciclul de viață al cheilor criptografice



Generarea cheilor

- Generatoare de numere aleatoare
 - pe un sistem de calcul este imposibil să se genereze numere complet aleatoare (John von Neumann) – nr. de stări ale sistemului este finit
 - pentru a obține un grad ridicat de securitate trebuie ca numerele generate să nu poată fi prezise sau reproduse
- Generatoare deterministe (pseudoaleatoare)
 - folosesc un algoritm pentru a genera numere pseudoaleatoare (FIPS 186-3)
- Generatoare non deterministe
 - surse fizice: zgomotul termic al tranzistoarelor, contoare Geiger-Muller, zgomot radio, etc

Distribuția cheilor

- Cea mai critică operație!
- Sisteme criptografice simetrice
 - curier de încredere (valiza diplomatică)
 - Quantum Key Distribution
- Sisteme criptografice cu chei publice
 - Certificate digitale
 - Cum se distribuie certificatele autorităților rădăcină?

Instalarea cheilor

- Pe disk, în fișiere
 - Criptate cu parolă (PKCS #12)
 - Acces restricționat de către sistemul de operare
- Pe dispozitive criptografice
 - Hardware Security Module (HSM)
 - Smart Card, USB dongle (token)

Salvarea / Restaurarea cheilor

- Se salvează doar cheile de decriptare a datelor
 - refacerea datelor în cazul pierderii chei
 - accesul la date în caz de nevoie (key escrow)
- Sisteme speciale care să asigure atât integritatea cât și controlul accesului
 - scheme “m din n” pentru accesul la chei
- Cheile de semnătură nu trebuie salvate!
 - se pierde caracterul de non-repudiere al semnăturilor

Utilizarea cheilor

- Încărcarea cheilor în memorie
 - ștergerea zonei după dealocare
- Autentificarea fiecărui acces
- Interfețe utilizator de încredere
 - key loggers
 - fake interfaces

Arhivarea cheilor

- Sisteme speciale care să asigure atât integritatea cât și controlul accesului
- Amprente de timp asociate fiecărei chei introduse în arhivă
- Cheile arhivate nu trebuie folosite niciodată în producție!

Ștergerea (terminarea) cheilor

- Ștergerea datelor de pe mediile de stocare nu este simplă!
 - comanda de ștergere a unui fișier marchează spațiu ocupat de fișierul respectiv ca fiind liber
 - alinierea capetelor de citire / scriere la un hard disc nu este perfectă
- Algoritmi speciali de ștergere a datelor (wipe)
 - suprascrierea repetată cu valori aleatoare
- Cheile trebuie șterse imediat ce nu mai este nevoie de ele

Algoritmi criptografici recomandați

- Funcții hash
 - SHA-2 (224, 256, 384, 512 biți)
 - SHA-3 (Keccak)
- Algoritmi simetrici
 - AES - lungime bloc date 128 biți, lungime cheie 128, 256 biți
 - TDEA (3DES) - lungime bloc date 64 biți, lungime cheie 3x56 biți
- Algoritmi cu chei publice (asimetrice)
 - Semnături digitale
 - RSA, DSA, ECDSA
 - Schimbul de chei
 - DH, anvelopare RSA

Lungimea cheilor

- “Spargerea” DES-ului prin forță brută
 - Electronic Frontier Foundation, 1998
 - DES Deep Crack, peste 90 miliarde chei pe secundă
 - 4.5 zile pentru a sparge o cheie DES de 56 biți
 - distributed.net, 1999
 - 250 miliarde chei pe secundă
- Dificultatea unui atac prin forță brută crește exponențial cu lungimea cheii!

Lungimi de chei recomandate

Date	Security Strength	Symmetric Algorithms	Factoring Modulus	Discrete Logarithm Key Group	Elliptic Curve	Hash (A)	Hash (B)
Legacy	80	2TDEA	1024	160 1024	160	SHA-1	
2019 - 2030	112	(3TDEA) AES-128	2048	224 2048	224	SHA-224 SHA-512/224 SHA3-224	
2019 - 2030 & beyond	128	AES-128	3072	256 3072	256	SHA-256 SHA-512/256 SHA3-256	SHA-1 KMAC128
2019 - 2030 & beyond	192	AES-192	7680	384 7680	384	SHA-384 SHA3-384	SHA-224 SHA-512/224 SHA3-224
2019 - 2030 & beyond	256	AES-256	15360	512 15360	512	SHA-512 SHA3-512	SHA-256 SHA-512/256 SHA-384 SHA-512 SHA3-256 SHA3-384 SHA3-512 KMAC256

<https://www.keylength.com/en/>

Best practices

- Conștientizarea utilizatorilor de importanța gestiunii corecte a cheilor criptografice
 - responsabilități și implicații posibile
- Elaborarea unui plan care să trateze cazul în care cheile au fost compromise
 - planul trebuie să existe înainte ca sistemul să devină operațional
- Folosirea de algoritmi și module criptografice validate
 - FIPS 140-2 Level 1 / 2 / 3

Best practices (cont.)

- În general, o cheie trebuie folosită doar într-un singur scop (criptare, semnare, etc)
- Cheile trebuie schimbate cât mai des posibil
- Se recomandă ca stocarea cheilor să se facă pe dispozitive criptografice (HSM, smart cards, etc)

Referințe

- ENISA – “Algorithms, Key Sizes and Parameters Report, 2014 Recommendations”
- NIST SP 800-57 - “Recommendation for Key Management”, Part 1
- A. J. Halderman, “Lest We Remember: Cold Boot Attacks on Encryption Keys”, 2008
- D. Genkin, “RSA Key Extraction via Low-Bandwidth Acoustic Cryptanalysis”, 2014

